

Full Name ZUBAIR SUMAYYAH AJIKE

Registration Number C11/26/CGRE/175962

Email Address Zubairsumayyah06@gmail.com

Cohort / Batch 11

Date Submitted 9-28-2026

Evidence Bundle 1 — Auditd Configuration and Events

1. Objective

The objective of this evidence bundle was to verify that the Linux **auditd** subsystem was operational, confirm that security-relevant audit rules were configured, generate and query audit events, and use **aureport** to summarize the collected audit information.

The evidence focuses on monitoring sensitive files, program execution, authentication-related activity, and overall audit activity.

2. Auditd Configuration

The following custom audit rules were configured:

```
-w /etc/passwd -p rwx -k passwd_changes  
-w /etc/shadow -p rwx -k shadow_changes  
-a always,exit -F arch=b64 -S execve -k program_execution  
-a always,exit -F arch=b32 -S execve -k program_execution  
-w /var/log/auth.log -p wa -k auth_failures
```

Purpose of the rules

Audit rule	Purpose
passwd_changes	Monitors access to /etc/passwd
shadow_changes	Monitors access to /etc/shadow
program_execution	Records program execution through execve
auth_failures	Monitors changes to /var/log/auth.log

The event should therefore be interpreted as evidence of audited access, rather than automatically being classified as a security incident.

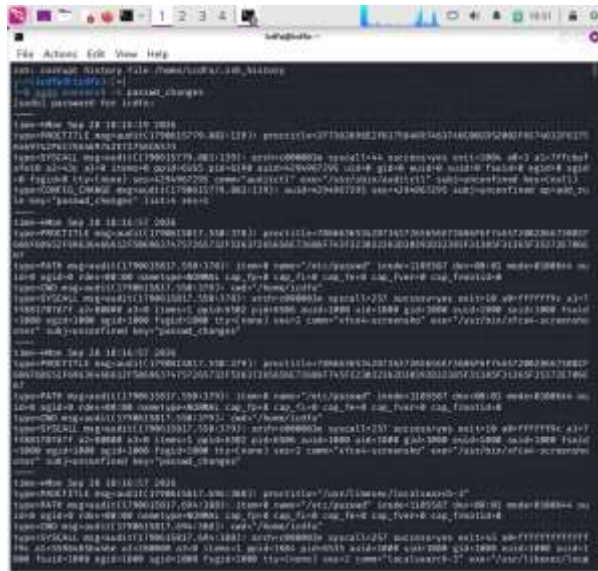


Figure 2: ausearch result for the passwd 1

4. Program Execution Evidence

The following command was used:

```
sudo ausearch -k program_execution
```

The results confirmed that the audit system was capturing program-execution events.

Examples observed in the audit records included execution of:

```
/usr/bin/ip
```

```
/usr/bin/dash
```

```
/usr/sbin/unix chkpwd
```

The events contained:

```
key="program execution"
```

and successful execution results.

For example, an ip command was recorded with the execution path:

```
exe="/usr/bin/ip"
```

and:

success=yes

This demonstrates that the program_execution rule was functioning and successfully recording execve activity.

The presence of these execution events does not automatically indicate malicious behavior. Commands such as ip and authentication-related utilities such as unix_chkpwd can be part of normal system operations.

Governance significance

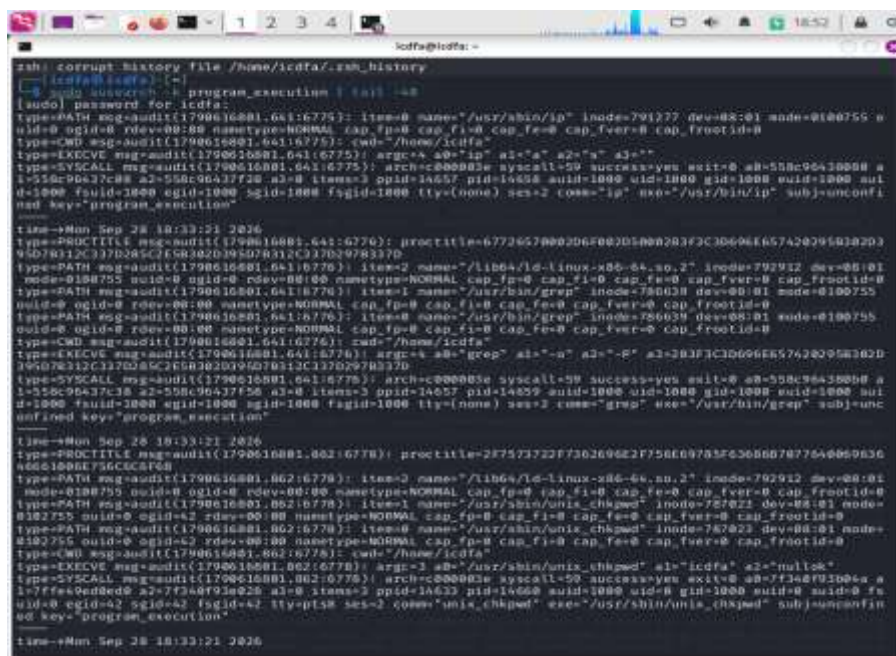
Program-execution auditing provides accountability and traceability. If an unauthorized or suspicious process were executed, the audit trail could provide information about:

what program was executed;

when it was executed;

which user context was associated with it; and

which terminal/session was involved.



```
zsh: corrupt history file /home/icdffa/.zsh_history
[icdffa@icdffa ~]$
type=EXECVE msg=audit(1790616801.641:6775): item=0 name="/usr/sbin/ip" inode=791277 dev=08:01 mde=0100755 u
uid=0 egid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1790616801.641:6775): cwd="/home/icdffa"
type=EXECVE msg=audit(1790616801.641:6775): argc=4 a0="ip" a1="a" a2="s" a3=""
type=SYSCALL msg=audit(1790616801.641:6775): arch=c000003e syscall=59 success=yes exit=0 a0=558c96430000 a
1=558c96437c00 a2=558c96437f20 a3=0 items=3 ppid=14657 pid=14658 uid=1000 uid=1000 gid=1000 uid=1000 aui
d=1000 fsuid=1000 egid=1000 sgid=1000 tty=(none) ses=2 comm="ip" exe="/usr/bin/ip" subj=unconfi
ned key="program_execution"

time--Mon Sep 28 10:13:21 2026
type=PROCTITLE msg=audit(1790616801.641:6776): proctitle=6773657000206F08D1000283F3C3D696E657A20295030203
9D70112C37D085C2F583020395D70312C37D02978337D
type=PATH msg=audit(1790616801.641:6776): item=2 name="/lib64/ld-linux-x86-64.so.2" inode=792912 dev=08:01
mode=0100755 uid=0 egid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(1790616801.641:6776): item=1 name="/usr/bin/grep" inode=786028 dev=08:01 mode=0100755
uid=0 egid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(1790616801.641:6776): item=0 name="/usr/bin/grep" inode=786039 dev=08:01 mode=0100755
uid=0 egid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1790616801.641:6776): cwd="/home/icdffa"
type=EXECVE msg=audit(1790616801.641:6776): argc=4 a0="grep" a1="-a" a2="-P" a3=203F3C3D696E657A20295030203
9D70112C37D085C2F583020395D70312C37D02978337D
type=SYSCALL msg=audit(1790616801.641:6776): arch=c000003e syscall=59 success=yes exit=0 a0=558c96430000 a
1=558c96437c00 a2=558c96437f20 a3=0 items=3 ppid=14657 pid=14659 uid=1000 uid=1000 gid=1000 uid=1000 aui
d=1000 fsuid=1000 egid=1000 sgid=1000 tty=(none) ses=2 comm="grep" exe="/usr/bin/grep" subj=unc
onfined key="program_execution"

time--Mon Sep 28 10:13:21 2026
type=PROCTITLE msg=audit(1790616801.602:6778): proctitle=287573722F7302696E2F758E09703F6308067077640069636
40661000E756CCCF08
type=PATH msg=audit(1790616801.602:6778): item=2 name="/lib64/ld-linux-x86-64.so.2" inode=792912 dev=08:01
mode=0100755 uid=0 egid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(1790616801.602:6778): item=1 name="/usr/sbin/unix_chkpwd" inode=787023 dev=08:01 mode=
0100755 uid=0 egid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(1790616801.602:6778): item=0 name="/usr/sbin/unix_chkpwd" inode=787023 dev=08:01 mode=
0100755 uid=0 egid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1790616801.602:6778): cwd="/home/icdffa"
type=EXECVE msg=audit(1790616801.602:6778): argc=2 a0="/usr/sbin/unix_chkpwd" a1="icdffa" a2="null0"
type=SYSCALL msg=audit(1790616801.602:6778): arch=c000003e syscall=59 success=yes exit=0 a0=7f3d0f93b06a a
1=7f3d0f9d8ed0 a2=7f3d0f9d8e20 a3=0 items=3 ppid=14633 pid=14660 uid=1000 uid=1000 gid=1000 uid=1000 aui
d=1000 fsuid=1000 egid=1000 sgid=1000 tty=pts0 ses=2 comm="unix_chkpwd" exe="/usr/sbin/unix_chkpwd" subj=unconfi
ned key="program_execution"

time--Mon Sep 28 10:13:21 2026
```

Figure 3: program_execution events captu 1

5. Authentication Audit Evidence

The following command was used:

sudo ausearch -k auth_failures

The returned records showed configuration changes involving the auth_failures rule.

The records included:

op=add_rule key="auth_failures"

and:

op=remove_rule key="auth_failures"

followed by another:

op=add_rule key="auth_failures"

Interpretation

These records demonstrate that the auth_failures audit rule was configured, removed, and subsequently re-added during the testing period.

Importantly, these records are audit-rule configuration events, not evidence of failed authentication attempts.

Therefore, the output does not provide evidence that a failed login occurred.

Governance significance

This distinction is important for accurate security reporting. Governance personnel should distinguish between:

audit configuration changes;

authentication events; and

confirmed security incidents.

Incorrectly reporting a rule configuration event as a failed login could lead to inaccurate security metrics and inappropriate escalation.

The two failed system calls should not be interpreted as failed login attempts because system-call failures and authentication failures represent different audit-event categories.

Governance significance

The aureport summary provides management-level evidence that audit monitoring was operational and producing measurable security records.

It can support governance activities such as:

security monitoring;

auditability;

accountability;

control effectiveness assessment; and

security reporting.

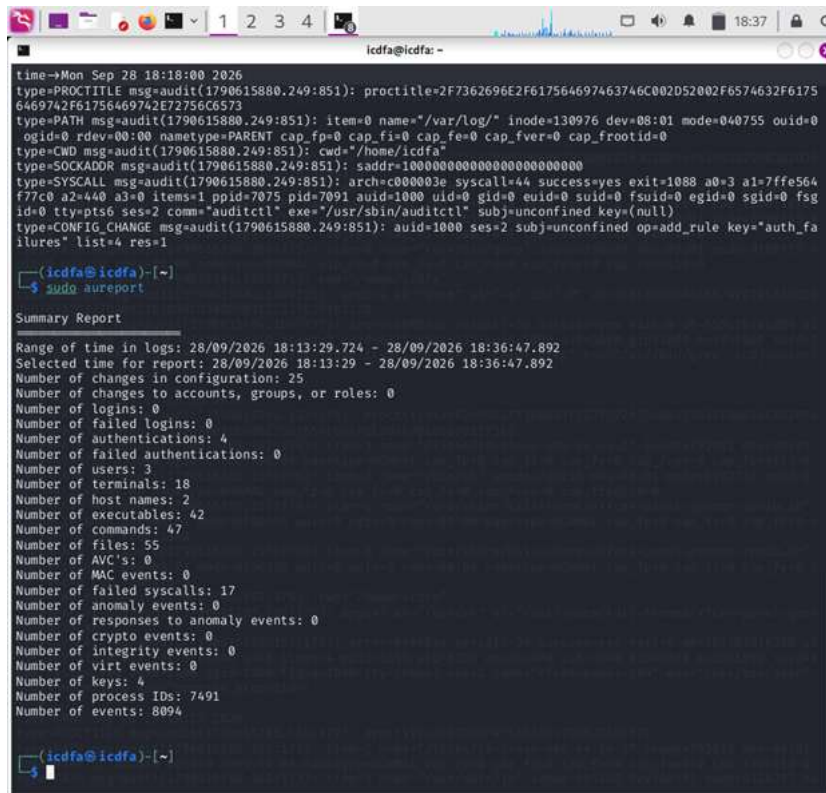


Figure 5: aureport audit summary

7. Failed Audit Events

The following command was used:

```
sudo aureport --failed
```

The report showed:

Number of failed logins: 0

Number of failed authentications: 0

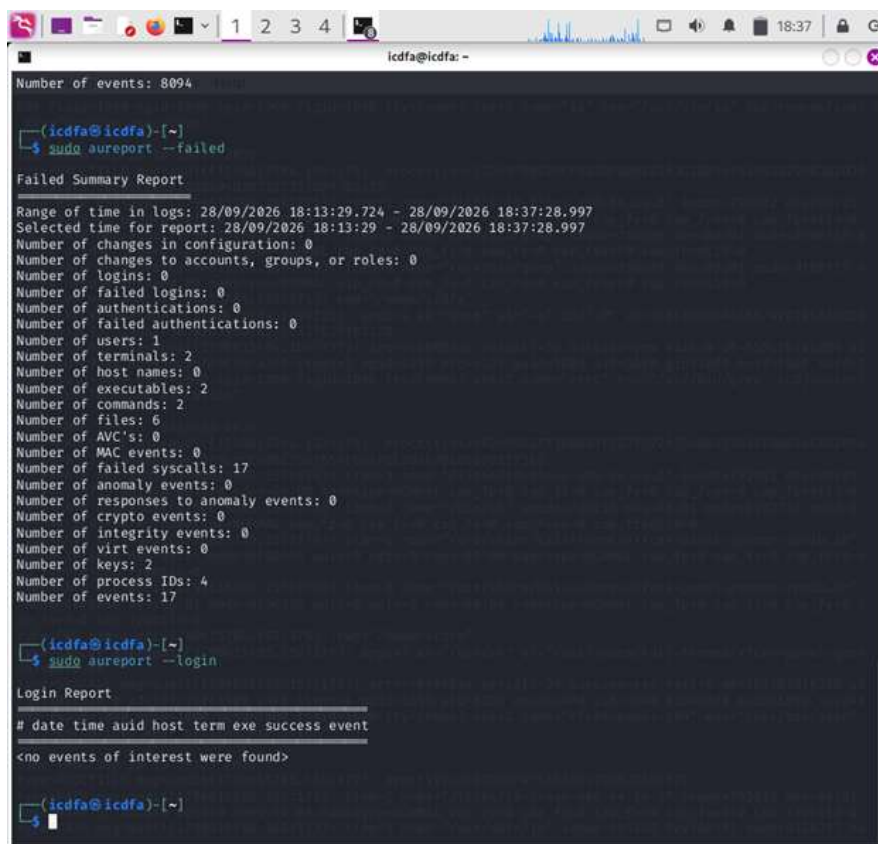
Number of failed syscalls: 2

No failed login or failed authentication events were identified in the audit period covered by the report.

Two failed system calls were recorded. The available evidence does not by itself establish the reason for those failures or indicate that they represent malicious activity.

Governance significance

This demonstrates the importance of establishing appropriate thresholds for security-event investigation. A failed system call may require technical investigation, but escalation should be based on context, frequency, affected process, and other supporting evidence.



```
icdfa@icdfa: ~  
Number of events: 8094  
  
(icdfa@icdfa)~  
$ sudo aureport --failed  
  
Failed Summary Report  
Range of time in logs: 28/09/2026 18:13:29.724 - 28/09/2026 18:37:28.997  
Selected time for report: 28/09/2026 18:13:29 - 28/09/2026 18:37:28.997  
Number of changes in configuration: 0  
Number of changes to accounts, groups, or roles: 0  
Number of logins: 0  
Number of failed logins: 0  
Number of authentications: 0  
Number of failed authentications: 0  
Number of users: 1  
Number of terminals: 2  
Number of host names: 0  
Number of executables: 2  
Number of commands: 2  
Number of files: 6  
Number of AVC's: 0  
Number of MAC events: 0  
Number of failed syscalls: 17  
Number of anomaly events: 0  
Number of responses to anomaly events: 0  
Number of crypto events: 0  
Number of integrity events: 0  
Number of virt events: 0  
Number of keys: 2  
Number of process IDs: 4  
Number of events: 17  
  
(icdfa@icdfa)~  
$ sudo aureport --login  
  
Login Report  
# date time audit host term exe success event  
<no events of interest were found>  
  
(icdfa@icdfa)~  
$
```

Figure 6: aureport --failed results 1

8. Login Report

The login activity was reviewed using:

sudo aureport --login

The result was:

<no events of interest were found>

Interpretation

No login events meeting the report's criteria were identified within the selected audit period.

Governance significance

The result provides additional evidence that no login-related event of interest was identified during the captured period. However, this conclusion is limited to the available audit records and observation window.

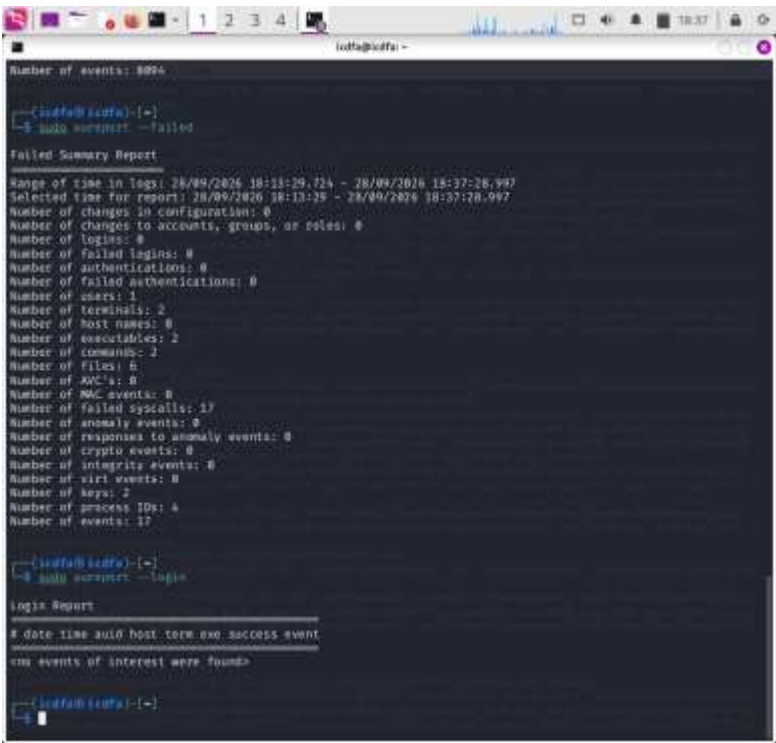


Figure 7: aureport --login results 1

9. Evidence Assessment

The auditd evidence demonstrates that the Linux system was capable of generating and querying security audit records.

The following controls were demonstrated:

Control	Evidence	Assessment
---------	----------	------------

Sensitive-file monitoring	passwd_changes events	Audit rule successfully captured /etc/passwd access
Program-execution monitoring	program_execution events	Program execution was successfully recorded
Authentication monitoring	auth_failures rule	Rule configuration was recorded; no failed authentication was established
Audit reporting	aureport	Audit activity was successfully summarized
Failed-event monitoring	aureport --failed	0 failed logins and 0 failed authentications observed
Login monitoring	aureport --login	No events of interest identified

10. Governance Conclusion

The auditd evidence provides technical assurance that security-relevant system activity was being recorded and could be queried using audit keys and summarized using aureport.

The evidence showed 1,681 audit events, including configuration changes, authentication activity, program execution, and file-related activity. No failed login or failed authentication was recorded during the observed period.

The /etc/passwd events demonstrate that sensitive-file access was being monitored. However, because the audit rule monitors several types of access, the observed events should not automatically be interpreted as evidence of unauthorized modification.

Overall, the evidence demonstrates the value of translating technical audit records into governance information. Rather than treating every audit event as an incident, security personnel should evaluate the event type, user context, process, outcome, and surrounding activity before determining whether escalation is required.

Evidence Bundle 2 — System and Authentication Logs

1. Objective

The objective of this evidence bundle was to review Linux system and authentication logs to identify security-relevant events, authentication failures, system errors, and other activities that may require investigation.

The following log sources were examined:

- /var/log/auth.log
- journalctl
- error-level journal entries
- authentication-related sudo events

2. Authentication Log Review

The authentication log was reviewed using:

```
sudo journalctl -f /auth.log
```

and authentication-related entries were examined.

The logs contained several authentication-related events on **28 September 2026**.

Observed events

At approximately **19:17:17**, the authentication log recorded:

```
pam_unix(sudo:auth): conversation failed
```

followed by:

```
pam_unix(sudo:auth): auth could not identify password for [icdfa]
```

At approximately **19:17:20**, another event was recorded:

```
unix_chkpwd: password check failed for user (icdfa)
```

and:

```
pam_unix(sudo:auth): authentication failure;  
logname=icdfa uid=1000 euid=0 tty=/dev/pts/11  
ruser= rhost=  
user=icdfa
```

Interpretation

These records provide **actual authentication-failure evidence**, unlike the earlier `ausearch -k auth_failures` results, which mainly showed audit-rule configuration events.

The events indicate that a sudo authentication attempt associated with user `icdfa` failed because the password could not be successfully identified or verified.

The evidence also shows that the authentication attempt occurred from a local terminal:

```
tty=/dev/pts/11
```

with:

```
uid=1000
```

```
euid=0
```

Security significance

Failed authentication attempts are security-relevant because repeated or unusual failures can indicate:

- incorrect password entry;
- an improperly configured authentication process;
- unauthorized access attempts; or
- attempted privilege escalation.

However, **one or a small number of failed authentication events does not by itself establish malicious activity**. The surrounding context and frequency should be reviewed.

Governance significance

Authentication failures should be monitored because they provide evidence about the effectiveness of access-control and privileged-access controls.

Organizations can establish thresholds—for example, repeated failures within a defined period—to determine when an event should be investigated or escalated.

The combination is worth documenting because privileged access represents a security-sensitive activity. The audit trail allows administrators to determine when root-level sessions were opened and closed.

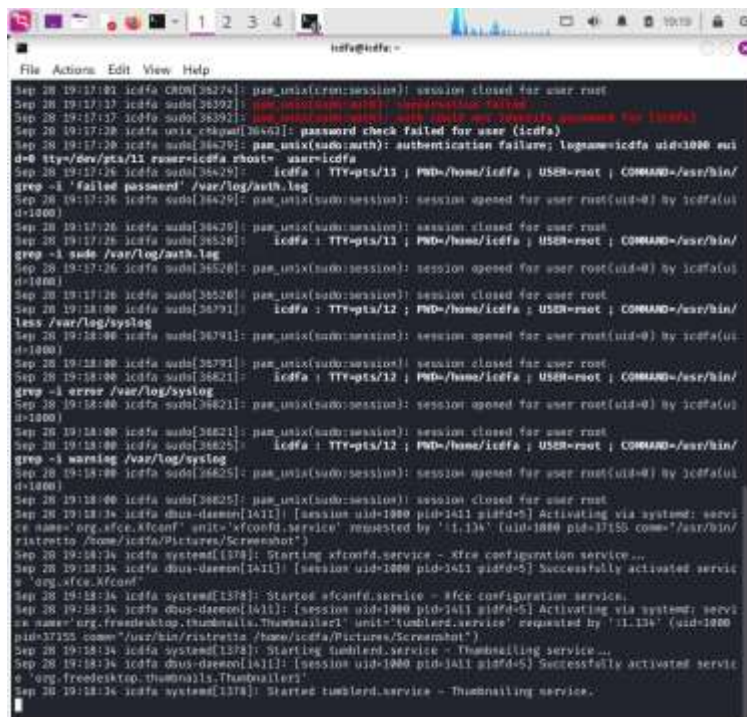
The evidence does not, by itself, establish unauthorized privilege escalation because sudo may have been legitimately used by the laboratory user.

Governance significance

Privileged-access activity should be logged and monitored because root-level access can make significant changes to the system.

The logs provide accountability by recording:

- the initiating user;
- the privileged account;
- the terminal;
- the time of the session; and
- the opening and closing of the session.



```
icdffa@icdffa:~  
File Actions Edit View Help  
Sep 28 19:17:02 icdffa CRON[38374]: pam_unix(cron:session): session closed for user root  
Sep 28 19:17:17 icdffa sudo[38392]: : pam_unix(sudo:session): session opened for user root(uid=0) by icdffa(uid=1000)  
Sep 28 19:17:17 icdffa sudo[38392]: : pam_unix(sudo:session): session closed for user root  
Sep 28 19:17:20 icdffa sshd[38402]: password check failed for user (icdffa)  
Sep 28 19:17:20 icdffa sudo[38402]: pam_unix(sudo:auth): authentication failure; logname=icdffa uid=1000 euid=0 tty=/dev/pts/11 ruser=icdffa rhost= user=icdffa  
Sep 28 19:17:26 icdffa sudo[38429]: icdffa : TTY=pts/11 ; PWD=/home/icdffa ; USER=root ; COMMAND=/usr/bin/grep -i failed password /var/log/auth.log  
Sep 28 19:17:26 icdffa sudo[38429]: pam_unix(sudo:session): session opened for user root(uid=0) by icdffa(uid=1000)  
Sep 28 19:17:26 icdffa sudo[38429]: pam_unix(sudo:session): session closed for user root  
Sep 28 19:17:26 icdffa sudo[38429]: icdffa : TTY=pts/11 ; PWD=/home/icdffa ; USER=root ; COMMAND=/usr/bin/grep -i sudo /var/log/auth.log  
Sep 28 19:17:26 icdffa sudo[38429]: pam_unix(sudo:session): session opened for user root(uid=0) by icdffa(uid=1000)  
Sep 28 19:17:26 icdffa sudo[38429]: pam_unix(sudo:session): session closed for user root  
Sep 28 19:17:26 icdffa sudo[38429]: icdffa : TTY=pts/12 ; PWD=/home/icdffa ; USER=root ; COMMAND=/usr/bin/less /var/log/syslog  
Sep 28 19:18:00 icdffa sudo[38791]: pam_unix(sudo:session): session opened for user root(uid=0) by icdffa(uid=1000)  
Sep 28 19:18:00 icdffa sudo[38791]: pam_unix(sudo:session): session closed for user root  
Sep 28 19:18:00 icdffa sudo[38821]: icdffa : TTY=pts/12 ; PWD=/home/icdffa ; USER=root ; COMMAND=/usr/bin/grep -i error /var/log/syslog  
Sep 28 19:18:00 icdffa sudo[38821]: pam_unix(sudo:session): session opened for user root(uid=0) by icdffa(uid=1000)  
Sep 28 19:18:00 icdffa sudo[38821]: pam_unix(sudo:session): session closed for user root  
Sep 28 19:18:00 icdffa sudo[38825]: icdffa : TTY=pts/12 ; PWD=/home/icdffa ; USER=root ; COMMAND=/usr/bin/grep -i warning /var/log/syslog  
Sep 28 19:18:00 icdffa sudo[38825]: pam_unix(sudo:session): session opened for user root(uid=0) by icdffa(uid=1000)  
Sep 28 19:18:00 icdffa sudo[38825]: pam_unix(sudo:session): session closed for user root  
Sep 28 19:18:13 icdffa dbus-daemon[1411]: [session uid=1000 pid=1411 pidfd=5] Activating via systemd: service name='org.xfce.Xfceconf' unit='xfce4.service' requested by '11.13k' (uid=1000 pid=37155 comm='/usr/bin/rstretto /home/icdffa/Pictures/Screenshots')  
Sep 28 19:18:14 icdffa systemd[1378]: Starting xfce4.service - Xfce configuration service...  
Sep 28 19:18:14 icdffa dbus-daemon[1411]: [session uid=1000 pid=1411 pidfd=5] Successfully activated service 'org.xfce.Xfceconf'  
Sep 28 19:18:14 icdffa systemd[1378]: Started xfce4.service - Xfce configuration service.  
Sep 28 19:18:14 icdffa dbus-daemon[1411]: [session uid=1000 pid=1411 pidfd=5] Activating via systemd: service name='org.freedesktop.thumbnails.Thumbnailer' unit='tumblerd.service' requested by '11.13k' (uid=1000 pid=37155 comm='/usr/bin/rstretto /home/icdffa/Pictures/Screenshots')  
Sep 28 19:18:14 icdffa systemd[1378]: Starting tumblerd.service - Thumbnailing service...  
Sep 28 19:18:14 icdffa dbus-daemon[1411]: [session uid=1000 pid=1411 pidfd=5] Successfully activated service 'org.freedesktop.thumbnails.Thumbnailer'  
Sep 28 19:18:14 icdffa systemd[1378]: Started tumblerd.service - Thumbnailing service.
```

4. Commands Executed During the Investigation

The authentication logs also captured commands executed through sudo.

For example:

COMMAND=/usr/bin/grep -i failed password /var/log/auth.log

and:

COMMAND=/usr/bin/grep -i sudo /var/log/auth.log

Other commands included searches against /var/log/syslog.

Interpretation

These entries are consistent with the investigation being performed during the laboratory. They demonstrate that privileged commands were themselves recorded in the authentication log.

This is useful because the log provides an audit trail of administrative activity.

Governance significance

Recording administrative commands supports accountability and non-repudiation. It allows an organization to determine which user initiated privileged actions and when those actions occurred.

5. System Journal Review

The journalctl output also contained system-level events.

The evidence included:

auditd[6161]: Audit daemon rotating log files

at approximately **19:16:42**.

The journal also showed normal service activity involving Xfce:

Started xfconf.service - Xfce configuration service.

and:

Started tumblerd.service - Thumbnailing service.

Interpretation

The journal contains a mixture of security-relevant, administrative, and normal operating-system events.

The Xfce and thumbnailing service messages appear to represent normal desktop-service activity rather than security incidents.

This demonstrates why log monitoring requires contextual analysis. A centralized log source can contain thousands of events, but not every event represents a security problem.

Normal operational events → warnings/errors → security-relevant events → incidents requiring escalation.

Figure 9: Linux journal and system activ 1

The most security-relevant events observed in this evidence bundle were the authentication failures at approximately **19:17:17–19:17:20**.

Time	Event	Assessment
19:17:17	sudo authentication conversation failed	Security-relevant
19:17:17	Password could not be identified for icdfa	Authentication failure
19:17:20	Password check failed for icdfa	Authentication failure
19:17:20	pam_unix authentication failure	Authentication failure
19:17:26	Root sudo session opened	Successful privileged access
19:17:26	Root sudo session closed	Privileged session ended
19:18:00	Root sudo session opened/closed	Privileged activity

Important distinction

These authentication failures are **different from the earlier auditd auth_failures output**.

The earlier:

```
sudo ausearch -k auth_failures
```

output showed **audit-rule configuration events**.

These screenshots show **actual authentication failures in the authentication log**.

That distinction is valuable in your report because it demonstrates that you correctly interpreted the evidence rather than simply treating every auth_failures search result as a failed login.

7. Governance Interpretation

The evidence demonstrates that Linux authentication and system activity can provide useful information for security governance.

The observed authentication failures should be considered in relation to the organization's access-control policy. If the failures were caused by incorrect password entry during legitimate administrative activity, they may represent routine operational events. If repeated or associated with unusual activity, they could warrant investigation.

The subsequent successful sudo sessions demonstrate why authentication monitoring should consider both failed and successful privileged-access events.

From a governance perspective, relevant monitoring questions include:

1. Are failed privileged authentication attempts monitored?
2. Is there a defined threshold for escalating repeated authentication failures?
3. Are successful root/sudo sessions logged?
4. Are privileged activities reviewed periodically?
5. Are authentication logs retained according to organizational requirements?
6. Are authentication events forwarded to a centralized SIEM?

8. Evidence Bundle 2 Conclusion

The system and authentication log review identified genuine authentication-related events, including failed password verification and sudo authentication failure for user icdfa at approximately **19:17:17–19:17:20 on 28 September 2026**.

The logs subsequently recorded successful root sudo sessions, demonstrating that privileged access activity was also being logged.

The journal evidence additionally showed audit daemon log rotation and normal desktop-service activity.

The evidence demonstrates the importance of contextual log analysis: **authentication failures are security-relevant events, but they should not automatically be classified as malicious without additional evidence.**

Evidence Bundle 3 — Lynis Security Audit

1. Objective

The objective of this evidence bundle was to use **Lynis** to assess the security configuration and hardening of the Linux laboratory system. The audit was used to establish a security-hardening baseline, identify configuration weaknesses, and translate the technical findings into security-governance and remediation requirements.

2. Lynis Audit Execution

The system was audited using Lynis. The completed audit produced the following summary:

Assessment item	Observed result
Lynis version	3.1.4
Hardening index	65
Tests performed	273
Plugins enabled	10
Firewall detected	Yes

Malware scanner detected	Yes
Vulnerability scan	Enabled
Security audit module	Enabled

The audit generated the following files:

/var/log/lynis.log

/var/log/lynis-report.dat

These files provide detailed records and report data from the security assessment.

```

File Actions Edit View Help
- Check the logfile for all details (less /var/log/lynis.log)
- Read security controls texts (https://cisofy.com)
- Use --upload to upload data to central system (Lynis Enterprise users)

Lynis security scan details:
Hardening index : 65 [#####]
Tests performed : 273
Plugin enabled : 1

Components:
- Firewall [V]
- Malware scanner [V]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] PenTest [ ]

Lynis modules:
- Compliance status [V]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

Lynis 3.1.4
Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)
2007-2024, CISOFY - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

[Tip] : Enhance Lynis audits by adding your settings to custom.conf (see /usr/lynis/default.conf for all se
tings)

iccf@picofra:~$

```

Figure 10: Lynis security audit summary 1

3. Lynis Hardening Index

The Lynis assessment produced a:

Hardening index: 65

The audit performed **273 tests** and had **10 plugins enabled**.

Interpretation

The hardening index provides a baseline indication of the security-hardening state identified by Lynis. It should **not** be interpreted as meaning that the system is “65% secure.”

Instead, the individual warnings and suggestions provide the actionable information required to determine which configurations may require improvement.

The result can be used as a baseline for future assessments. After applicable findings are remediated, Lynis can be run again to determine whether the system's hardening assessment has changed.

Governance significance

From an information-security governance perspective, establishing a baseline allows an organization to:

- measure security-hardening progress;
- identify configuration weaknesses;
- assign remediation responsibilities;
- track outstanding security actions; and
- provide evidence that security controls are periodically assessed.

4. Lynis Finding 1 — Password Aging Configuration

Lynis identified recommendations concerning password expiration and password-aging controls.

The audit reported:

Suggestion: When possible set expire dates for all password protected accounts
[test:AUTH-9282]

It also reported:

Suggestion: Configure minimum password age in /etc/login.defs
[test:AUTH-9286]

and:

Suggestion: Configure maximum password age in /etc/login.defs
[test:AUTH-9286]

Security issue

Password-aging controls determine how long passwords can remain valid and can form part of an organization's authentication-security policy.

The absence of appropriate password-aging configuration may make it more difficult to enforce an organization's approved password-lifecycle requirements.

Recommended remediation

The administrator should review the password policy and determine appropriate values for:

PASS_MIN_DAYS
PASS_MAX_DAYS

in:

/etc/login.defs

For example, the configuration can be reviewed with:

```
sudo grep -E 'PASS_MIN_DAYS|PASS_MAX_DAYS' /etc/login.defs
```

The values should be selected according to the organization's approved security policy rather than arbitrarily applying a value.

Governance significance

This finding relates to **Identity and Access Management (IAM)** and password-policy governance.

The organization should ensure that:

1. password requirements are formally defined;
2. Linux systems implement the approved requirements;
3. exceptions are documented; and
4. compliance can be periodically verified.

5. Lynis Finding 2 — Password Hashing Configuration

Lynis reported:

Suggestion: Configure password hashing rounds in /etc/login.defs
[test:AUTH-9230]

Security issue

Password hashing is an important mechanism for protecting stored authentication credentials.

Appropriate password-hashing configuration can increase the computational effort required to recover passwords from stolen password hashes.

Recommended remediation

The administrator should review the system's password-hashing configuration and determine whether appropriate hashing parameters should be configured.

The relevant configuration can be reviewed with:

```
sudo grep -n "SHA_CRYPT" /etc/login.defs
```

The administrator should verify which parameters are supported by the installed Linux/PAM configuration before making changes.

Governance significance

This finding relates to **credential protection**.

From a governance perspective, organizations should define requirements for protecting authentication credentials and verify that technical systems implement those requirements.

The finding should therefore be tracked as a security-hardening action and assigned an appropriate owner.

6. Lynis Finding 3 — Process Accounting

Lynis reported:

Suggestion: Enable process accounting
[test:ACCT-9622]

It also reported:

Suggestion: Enable sysstat to collect accounting (disabled)
[test:ACCT-9626]

Security issue

Process accounting can provide additional historical information about processes executed on a Linux system.

This information can be useful when investigating system activity, administrative actions, or potentially suspicious process execution.

Recommended remediation

The organization should determine whether process accounting is required for the system.

If required, the administrator can install and configure the appropriate accounting functionality for the Linux distribution.

For example, the administrator could first check whether the accounting package is installed:

```
dpkg -l | grep -E 'acct|psacct|sysstat'
```

The change should be implemented according to the organization's monitoring requirements and tested before being deployed broadly.

Governance significance

This finding relates directly to **security monitoring, logging, and accountability**.

Process accounting can supplement existing auditd monitoring and provide additional evidence when investigating:

- unauthorized program execution;
- privileged activity;
- system misuse; and
- security incidents.

7. Lynis Finding 4 — Firewall Warning

The Lynis output also contained an explicit warning:

```
Warning: iptables module(s) loaded, but no rules active  
[test:FIRE-4512]
```

Security issue

The warning indicates that the iptables kernel module was loaded while Lynis detected no active iptables rules.

This does **not automatically mean that the system has no firewall protection**, because another firewall framework or configuration could be in use. The actual firewall configuration therefore needs to be verified.

Recommended remediation

First determine which firewall mechanism is active.

For example:

```
sudo iptables -L -n -v
```

and:

```
sudo nft list ruleset
```

The administrator should determine whether the host is intentionally using iptables, nftables, another firewall solution, or no host-based firewall.

If the organization requires host-based firewall protection, appropriate rules should be configured according to the approved security baseline.

Governance significance

This finding relates to **network security and security configuration management**.

The organization should have a documented baseline specifying:

- whether host-based firewalls are required;
- which firewall technology should be used;
- which inbound/outbound traffic is permitted;
- who is responsible for managing firewall rules; and
- how firewall configurations are periodically reviewed.

8. Lynis Finding 5 — Outdated Lynis Release

The report also identified:

Suggestion: This release is more than 4 months old.

Check the website or GitHub to see if there is an update available.

Security issue

The installed Lynis release may not contain the latest improvements, tests, or security-assessment functionality.

Recommended remediation

Check whether a newer supported Lynis version is available and update the tool according to the organization's software-maintenance process.

Governance significance

Security assessment tools themselves should be maintained as part of the organization's security-tool lifecycle.

An organization should ensure that:

- security tools are periodically reviewed;
- supported versions are maintained;
- updates are evaluated;
- tool changes are documented; and
- security assessments use appropriate versions.

9. Additional Lynis Suggestions Observed

The audit also identified several other hardening recommendations.

These included:

Password strength

Lynis suggested installing a PAM module for password-strength testing, such as `pam_cracklib` or `pam_passwdqc`.

Default umask

The audit reported that a default umask in `/etc/login.defs` could not be found and indicated that a stricter setting could be considered.

Filesystem separation

Lynis suggested considering separate partitions for:

`/home`
`/var`

to reduce the impact of a filesystem becoming full.

Removable storage

The audit suggested disabling removable USB storage when it is not required to reduce the risk of unauthorized storage or data theft.

Unnecessary network protocols

The audit recommended determining whether protocols such as:

dccp
sctp
rds
tipc

are actually required on the system.

Logging

Lynis suggested enabling logging to an external logging host for archiving and additional protection.

Legal warning banner

Lynis suggested adding a legal banner to:

/etc/issue
/etc/issue.net

to warn unauthorized users.

File permissions

The audit recommended reviewing permissions on home directories and considering restrictions on compiler access.

These findings demonstrate that Lynis evaluates multiple dimensions of system security rather than focusing on a single control.

10. Selected Findings for Remediation

Finding	Lynis evidence	Security area	Recommended remediation
1. Password aging	AUTH-9282, AUTH-9286	Authentication/IAM	Review and configure appropriate

			password-aging requirements
2. Password hashing rounds	AUTH-9230	Credential protection	Review and configure appropriate hashing parameters
3. Process accounting	ACCT-9622, ACCT-9626	Monitoring/accountability	Evaluate and enable appropriate process-accounting capability

The firewall warning is retained as an **additional high-priority item for technical review**, rather than assuming that the absence of iptables rules means the system has no firewall.

11. Remediation Plan

ID	Finding	Proposed remediation	Responsible role	Verification
L1	Password aging	Review organizational password policy and configure appropriate PASS_MIN_DAYS and PASS_MAX_DAYS values	System Administrator	Re-run Lynis and verify /etc/login.defs
L2	Password hashing	Review supported hashing configuration and apply approved parameters	System Administrator/Security Administrator	Re-run Lynis and inspect configuration
L3	Process accounting	Determine whether process accounting is required and enable it if approved	System Administrator	Verify accounting service and rerun Lynis

L4	Firewall warning	Determine whether iptables, nftables, or another firewall is intended; configure according to baseline	Network/Security Administrator	Verify active rules and rerun Lynis
L5	Outdated Lynis	Check for an appropriate supported Lynis update	Security Administrator	Verify installed version after update

12. Governance Control Mapping

The Lynis findings can be translated into governance controls as follows:

Governance area	Technical evidence	Control objective	Monitoring indicator
Identity & Access Management	Password aging recommendations	Enforce approved authentication requirements	Percentage of systems meeting password-policy baseline
Credential Protection	Password hashing recommendation	Protect stored authentication credentials	Number of systems failing credential-protection baseline
Security Monitoring	Process-accounting recommendation	Maintain sufficient activity visibility	Percentage of monitored systems with required logging enabled
Network Security	Firewall warning	Maintain approved network-access controls	Number of systems with verified active firewall policy
Security Tool Management	Outdated Lynis recommendation	Maintain supported security-assessment tooling	Percentage of security tools on approved versions

13. Governance Issues Identified

Issue 1 — Authentication configuration requires review

Lynis identified multiple recommendations relating to password aging and password-hashing configuration. These should be compared against the organization's approved authentication policy.

Issue 2 — Additional process visibility may be required

The recommendation to enable process accounting indicates a potential gap in historical process-activity visibility.

This should be assessed against the organization's logging and monitoring requirements.

Issue 3 — Firewall configuration requires verification

Lynis reported that the iptables module was loaded but no active rules were detected.

The organization should verify whether another firewall mechanism is intentionally being used before treating this as a control failure.

Issue 4 — Security assessment tooling requires maintenance

Lynis reported that its installed release was more than four months old. The installed version should be evaluated against the organization's approved software-maintenance requirements.

14. Evidence Interpretation

The Lynis results demonstrate why technical security assessment should be connected to governance processes.

A technical recommendation does not automatically mean that a security control has failed. Each finding should be assessed against:

1. the organization's security policy;
2. the system's operational requirements;
3. the applicable security baseline;
4. the risk associated with the finding; and
5. whether an approved compensating control exists.

For example, the firewall warning requires verification because a host may use nftables or another firewall framework instead of active iptables rules.

Similarly, the password recommendations should be evaluated against the organization's approved password policy before specific configuration values are applied.

15. Evidence Bundle 3 Conclusion

The Lynis assessment provided a security-hardening baseline for the Linux laboratory system.

The assessment used **Lynis 3.1.4**, performed **273 tests**, and produced a **hardening index of 65**. The audit identified multiple security-hardening recommendations relating to authentication, credential protection, process accounting, filesystem security, network protocols, logging, and system configuration.

Three findings were selected for detailed remediation planning:

1. **Password-aging configuration**
2. **Password-hashing configuration**
3. **Process accounting**

An additional firewall warning was identified:

iptables module(s) loaded, but no rules active

This requires verification of the actual firewall technology and configuration before a final governance conclusion is made.

The assessment demonstrates how vulnerability and hardening-scanning results can be converted into actionable governance activities by assigning remediation responsibilities, defining verification methods, and tracking security controls against an established baseline.